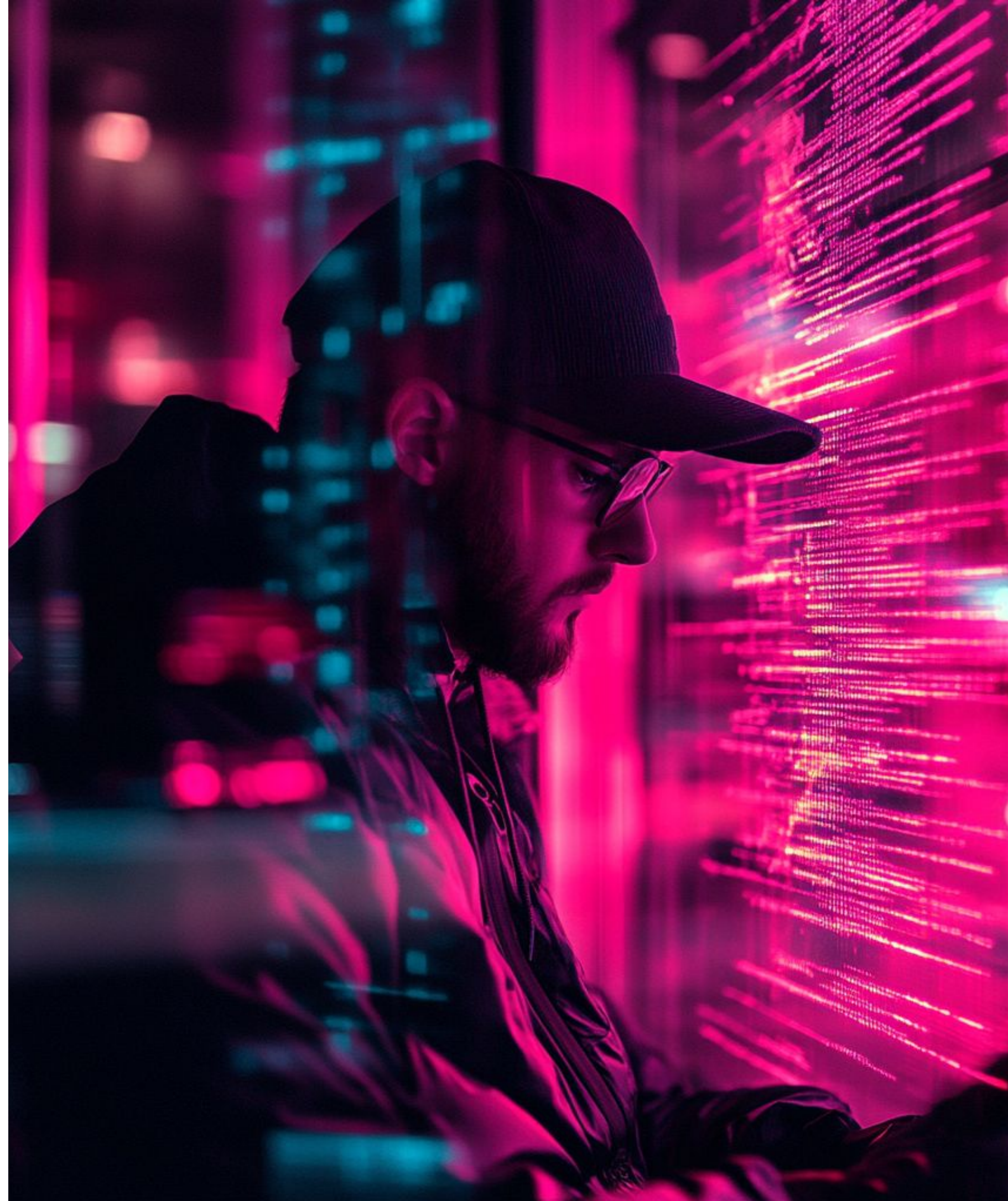


1. OVERVIEW

An overview of Requirement 11
("Test Regularly"), and its
sub-requirements.



REQ. 11: TEST REGULARLY

REQ. 11: TEST REGULARLY **OVERVIEW**

Requirement 11 (Test Security of Systems and Networks Regularly) is all about having processes and procedures to detect and address vulnerabilities of different types.

- It includes detecting both internal and external threats of multiple types;

This requirement focuses mostly on:

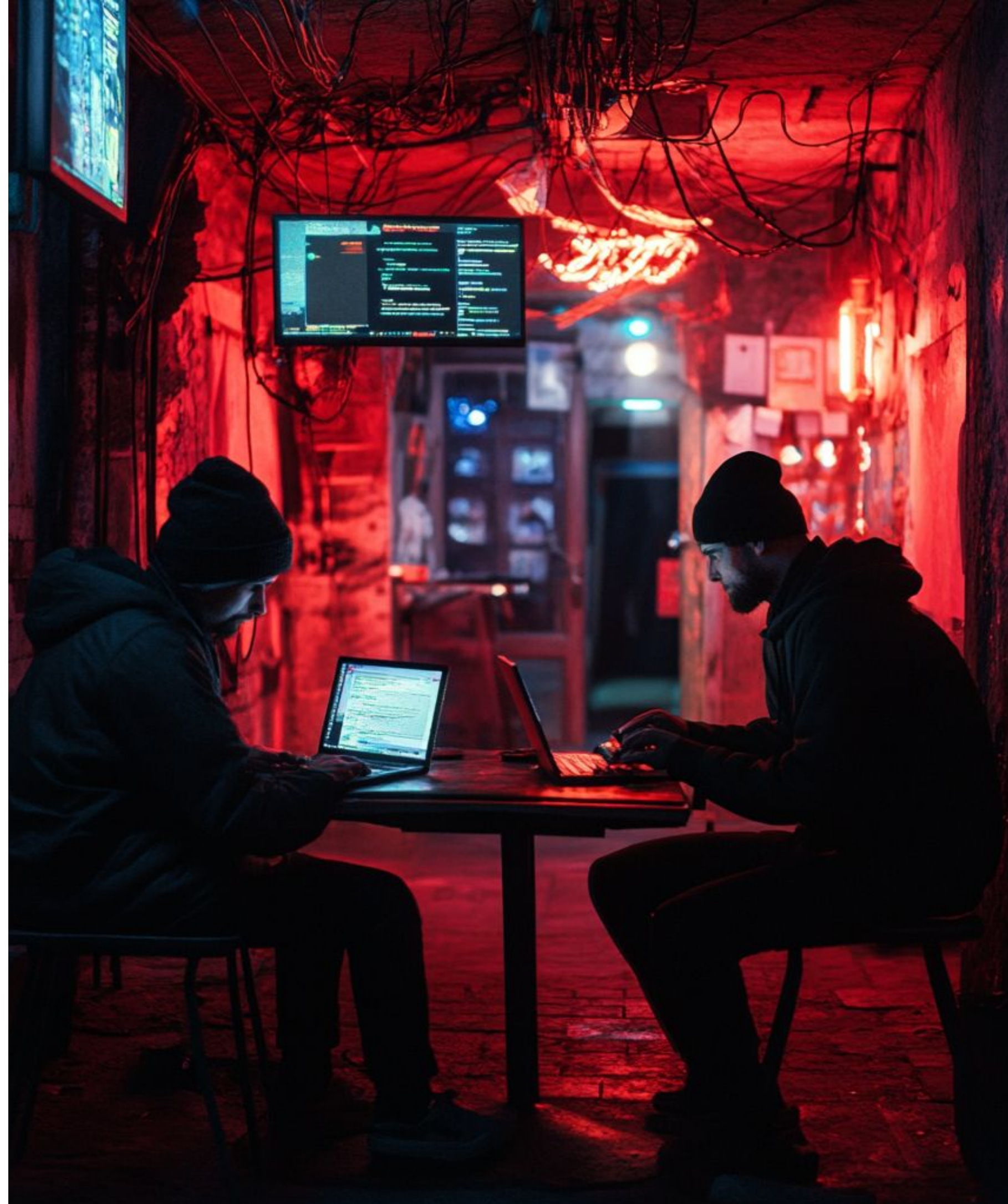
- Periodically ensuring you know what you have. Which APs, which systems, which protections, which vulnerabilities;
- Periodically ensuring you know how you react. How vulnerable are we to intrusions, to social engineering, etc;
- Ensuring reporting of incidents and issues is healthy;

REQ. 11: TEST REGULARLY OVERVIEW

The sub-requirements for this requirement include:

- 11.1 Processes and mechanisms for regularly testing security of systems and networks are defined and understood.
- 11.2 Wireless access points are identified and monitored, and unauthorized wireless access points are addressed.
- 11.3 External and internal vulnerabilities are regularly identified, prioritized, and addressed.
- 11.4 External and internal penetration testing is regularly performed, and exploitable vulnerabilities and security weaknesses are corrected.
- 11.5 Network intrusions and unexpected file changes are detected and responded to.
- 11.6 Unauthorized changes on payment pages are detected and responded to.





REQ. 11: TEST REGULARLY

REQ. 11: TEST REGULARLY **OVERVIEW**

11.1 Processes and mechanisms for regularly testing security of systems and networks are defined and understood

- This is our usual sub-requirement dictating that all policies and procedures must be identified and documented, as well as updated, in use, and the roles and responsibilities must also be documented, assigned and understood;

This is usually tested through:

- Examining the documentation and interviewing personnel, to verify that everything really is documented and managed as it should;
- Examining the details of the processes and roles, to make sure that everything really is in compliance;

REQ. 11: TEST REGULARLY **OVERVIEW**

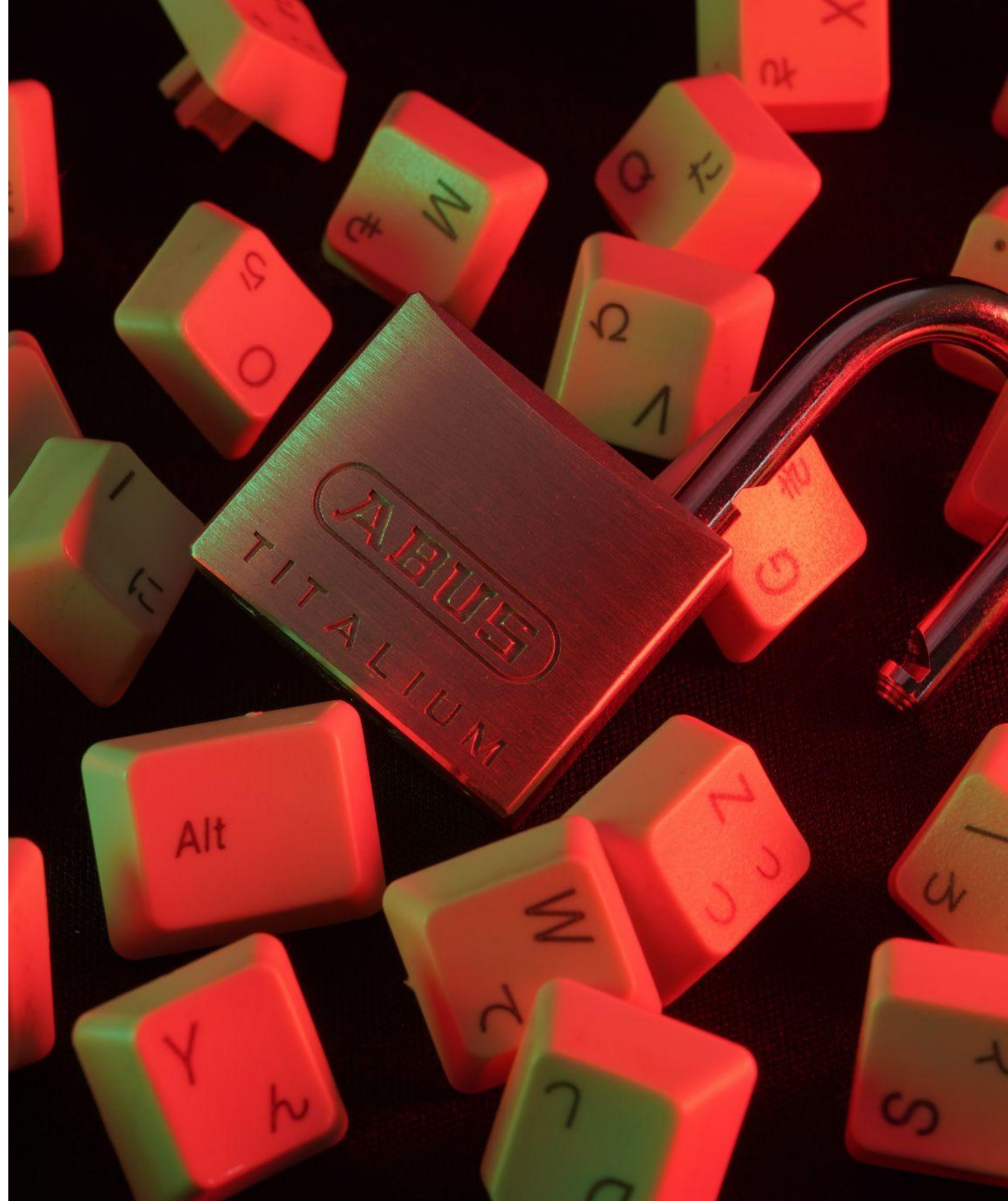
11.2 Wireless access points are identified and monitored, and unauthorized wireless access points are addressed

- Unauthorized (or “rogue”) Access Points are very dangerous. So we must periodically audit for these;
- Depending on our size, it may be physical checks, IDS/IPS...
- We need to also include an inventory of all legitimate APs, as well as the business justification for each;

This is usually tested through:

- Examining the policies and procedures regarding the inventorying and auditing of APs;
- Examining the documentation and interviewing people regarding the detection processes used;
- Examining the business justifications for authorized APs;





REQ. 11: TEST REGULARLY

REQ. 11: TEST REGULARLY **OVERVIEW**

11.3 External and internal vulnerabilities are regularly identified, prioritized, and addressed

- Both internal and external vulnerabilities must be scanned for, periodically. External scanning requires an ASV (Approved Scanning Vendor), internal does not;
- High-risk and critical vulnerabilities (CVSS > 4.0) must be addressed right away and scanning repeated. Lower-risk ones (≤ 3.9) are acceptable and can be addressed later;

This is usually tested through:

- Examining the scanning tool documentation, configurations, and past scan results;
- Auditing the CVSS score of vulnerabilities, and other elements such as external scans being done by ASVs;

REQ. 11: TEST REGULARLY **OVERVIEW**

11.4 External and internal penetration testing is regularly performed, and exploitable vulnerabilities and security weaknesses are corrected

- There must be a defined methodology (any is fine, defined);
- Penetration testing must be done, covering the entire CDE and critical systems, from inside and outside the network, at the network layer and app layer (relates to Req. 6), and documented. If using segmentation, controls are tested;
- Testers must be qualified, whether internal or external;

This is usually tested through:

- Examining documentation and interviewing personnel to ensure the pentesting methodology is defined + enforced;
- Examining pentesting records to ensure tester competence + correction of vulnerabilities;





REQ. 11: TEST REGULARLY

REQ. 11: TEST REGULARLY **OVERVIEW**

11.5 Network intrusions and unexpected file changes are detected and responded to

- This sub-requirement is, basically, about IDS/IPS systems and about FIM. We want to prevent intruders from entering our CDE, and we want to ensure no critical files are tampered with. Or, at least being warned of these;

This is usually tested through:

- Examining diagrams to ensure IDS/IPS systems cover the whole CDE, and examining FIM system documentation to ensure it covers all critical files;
- Ensuring FIM is run at least once a week for file integrity;
- Examining past records of both types of systems used;

REQ. 11: TEST REGULARLY **OVERVIEW**

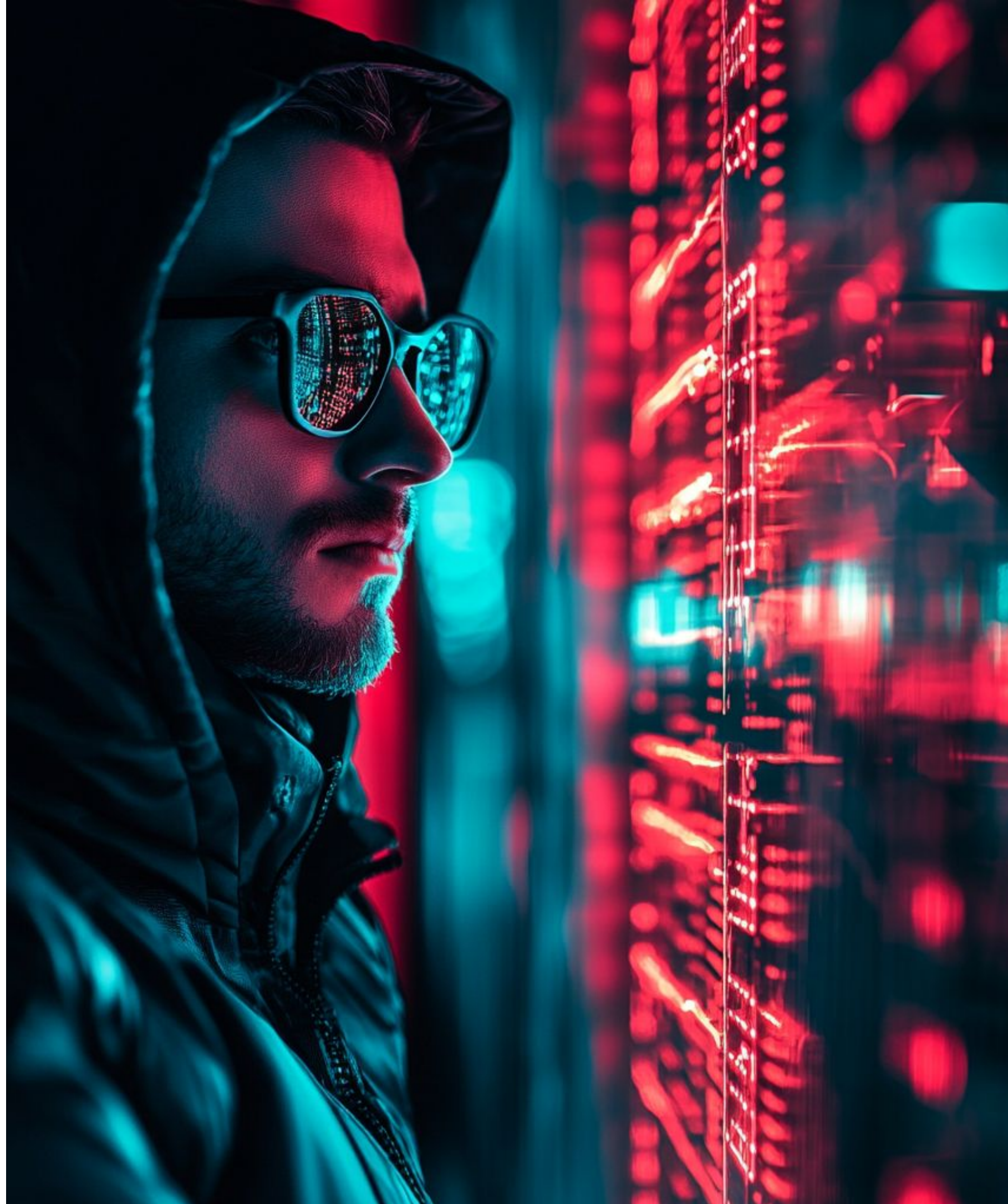
11.6 Unauthorized changes on payment pages are detected and responded to

- This is similar to ensuring integrity of critical files, but for our payment pages in websites. They cannot be tampered or compromised. To prevent skimming/injection attacks;
- We must have a system, such as Webpage Integrity Monitoring (WIM) or FIM on the website server, weekly;

This is usually tested through:

- Examining the documentation of the WIM/FIM/other mechanism, as well as past records of it and any alarms;
- Examining documentation and interviewing personnel to ensure this system is running on time and properly;





REQ. 11: TEST REGULARLY

REQ. 11: TEST REGULARLY **OVERVIEW**

How can we summarize, then, this requirement?

- We have to test for various types of vulnerabilities regularly;
- We must inventory authorized APs and detect unauthorized ones;
- We must scan for internal and external vulnerabilities regularly, with a specific methodology, and address them;
- We must perform internal and external pentesting regularly, with a given methodology, and address issues;
- We must have IDS/IPS systems to prevent or detect intruders, FIM to prevent or detect changes in critical files, and WIM/FIM to prevent or detect changes to payment pages in our websites/portals;

REQ. 11: TEST REGULARLY

OVERVIEW

EXAMPLES

/01 **VULNERAB. VS. PENTEST**

Vulnerability testing and penetration testing are often mistaken, but are different. VT is about reporting on possible vulnerabilities (general), pentests is specific.

/02 **INTERNAL + EXTERNAL**

Both internal and external pentesting is important. Many companies focus on protecting the organisation from outside attacks... but what if they are already in?

/03 **DEFINING “CRITICAL”**

Critical files to be protected by FIM or critical junctions to be defended by IDS/IPS include certain elements in all systems, but you may expand the definition.

REQ. 11: TEST REGULARLY

OVERVIEW

USE CASES

SMALL COFFEE SHOP

- The organization performs vulnerability scans of their PoS systems and networks for vulnerabilities;
- The organization routinely checks for unauthorized APs (physically and with an automated scanner);
- The organization additionally checks for signs of tampering on all physical devices owned;

E-COMMERCE STORE

- The organization employs qualified security professionals to perform annual penetration tests on their website + apps to uncover vulnerabilities;
- They perform quarterly scans of servers and networks with automated tools;
- They regularly test IDS/IPS systems for efficiency;

HOTEL CHAIN

- The organization conducts annual penetration testing across all locations' networks that handle CHD, to evaluate their security;
- They perform both internal and external vulnerability scans every quarter, addressing urgent vulnerabilities;
- They regularly test IR plans with drills and simulations;

PAYMENT PROCESSOR

- The organization implements ongoing security testing practices, including real-time vulnerability assessments and threat modeling, dealing with critical threats in close to real-time speed;
- Besides all other testing types, red team drills are used to simulate advanced attack scenarios;

REQ. 11: TEST REGULARLY

OVERVIEW

KEY TAKEAWAYS

/01 11.1 PROCESSES DEFINED

This is the usual sub-requirement about ensuring everything is defined and documented, and that people understand/acknowledge their roles.

/03 11.3 VULNERABILITY SCANS

Both internal and external vulnerabilities must be regularly scanned identified and addressed (external ones by an ASV), and addressed based on severity.

/05 11.5 IDS/IPS AND FIM

IDS/IPS systems must continually prevent or detect intruders, and FIM software must continually detect unauthorized changes to critical files.

/02 11.2 AP DETECTION

Both authorized and unauthorized APs must be detected with periodic scans, as well as keeping all authorized APs inventoried and justified.

/04 11.4 PENETRATION TESTS

Penetration tests must be done on the whole CDE perimeter, internal and external, at various layers, and with a specific methodology.

/06 11.6 CHANGES TO PAGES

A system such as WIM must continually detect possible tampering of payment pages in websites and portals to detect possibly unauthorized changes.